

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

Microsoft Rolled Out SPNEGO NEGOTEX Critical Vulnerability

Date of Publication

December 23, 2022

Admiralty Code

A1

TA Number

TA2022314

Summary

First Seen: September 2022

Affected Product: Windows operating systems

Impact: Remote attacker execute arbitrary code on the target system

CVEs

CVE	NAME	PATCH
CVE-2022-37958	Microsoft Pre-authentication Remote Code Execution vulnerability	
CVE-2017-0144	Microsoft SMBv1 Remote Code Execution Vulnerability	

Vulnerability Details

#1

Microsoft updated the severity level of the CVE-2022-37958 vulnerability from high to critical after discovering that threat actors can use the vulnerability to execute code remotely.

#2

This vulnerability was initially categorized as an information disclosure vulnerability, but it has now been identified as a SPNEGO Extended Negotiation (NEGOEX) Security Mechanism Remote Code Execution Vulnerability. The CVE-2017-0144 vulnerability affected the SMB protocol, whereas the CVE-2022-37958 vulnerability can affect a wide range of protocols.

#3

The vulnerability exists because of a boundary error in the implementation of the SPNEGO Extended Negotiation (NEGOEX) Security Mechanism.

#4

Any application implementing the NEGOEX authentication protocol can receive a customized request from a remote, unauthenticated attacker who can then cause memory corruption and run arbitrary code on the target system.



Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-37958	Windows 7 - XP Windows Servers 2003 - 2022 20H2	cpe:2.3:o:microsoft:windows:10:1706:*:*:*:*:*	CWE-119
CVE-2017-0144	Windows 7 - Vista Windows Servers 2008 - 2016	cpe:2.3:o:microsoft:windows:Vista:*:*:*:*:*	CWE-20

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Link' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0008</u> Lateral Movement	<u>TA0005</u> Defense Evasion
<u>TA0011</u> Command and Control	<u>T1021.001</u> Remote Desktop Protocol	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities
<u>T1021</u> Remote Services	<u>T1203</u> Exploitation for Client Execution	<u>T1071</u> Application Layer Protocol	<u>T1071.001</u> Web Protocols
<u>T1556</u> Modify Authentication Process			

Patch Links

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37958>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2017-0144>

References

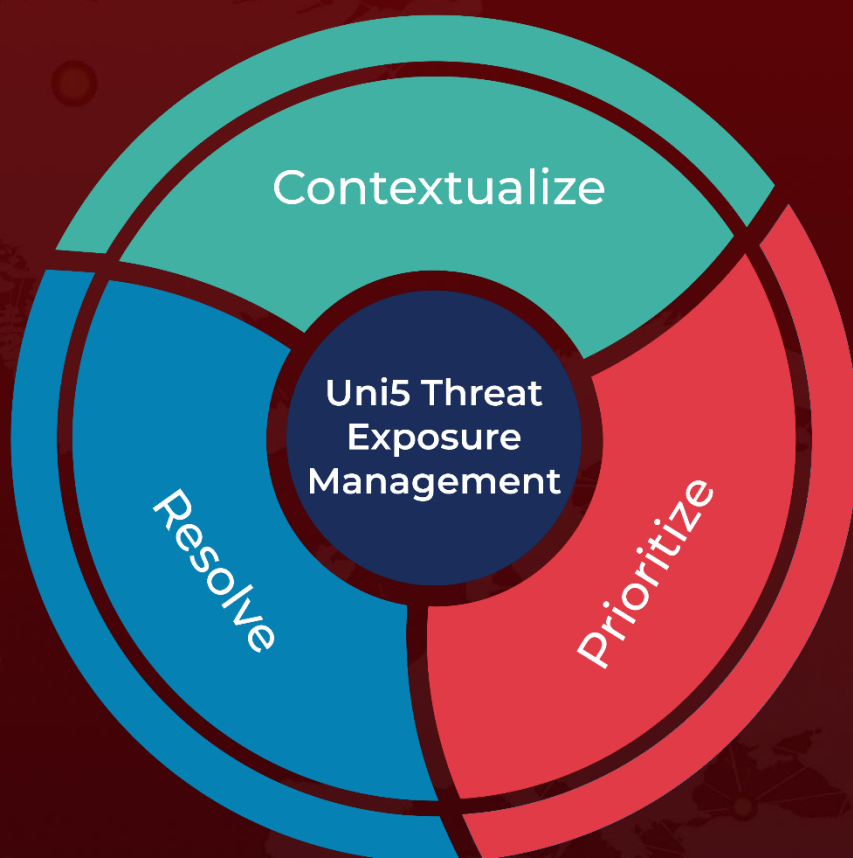
<https://www.tenable.com/blog/cve-2022-37958-faq-for-critical-microsoft-spnego-negoex-vulnerability>

<https://securityaffairs.co/wordpress/139709/hacking/microsoft-revised-cve-2022-37958-rate.html>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 23, 2022 • 6:30 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com